

Post-Incident Assessment Report (PIAR)

National Energy Ransomware Case Study

Contents

1.0 Introduction	2
2.0 Company Profile.....	2
3.0 Attack Timeline.....	2
4.0 Attack Analysis	3
4.1 Finding A – Third-Party risk management.....	3
4.2 Finding B – Identity and Privileged Access Management Failures.....	5
4.3 Finding C – Authentication Control Deficiency	6
4.4 Finding D – Network Segmentation and Lateral Movement Controls	7
4.5 Finding E – Security Monitoring and Incident Detection	8
4.6 Finding F – Endpoint Security Controls	9
4.7 Overall Opinion	10
5.0 Recommendations	11
5.1 Recommendation A – Implement Enterprise Endpoint Detection and Response (Critical).....	11
Observation.....	Error! Bookmark not defined.
5.2 Recommendation B – Strengthen Identity and Privileged Access Management (Critical)	12
Observation.....	Error! Bookmark not defined.
5.3 Recommendation C – Improve Network Security Architecture (High)	13
Observation.....	Error! Bookmark not defined.
5.4 Recommendation D – Strengthen Third-Party Risk Management (High)	14
Observation.....	14
5.5 Recommendation E – Strengthen Backup and Recovery Controls (High)	15
Observation.....	15
5.6 Recommendation F – Formalize Security Monitoring and Incident Response (High)	17
Observation.....	17
5.7 Recommendation G – Enhance Security Communication and Security Awareness (Medium)	19
Observation.....	19
6.0 Conclusion	20
7.0 References.....	20

1.0 INTRODUCTION

This Post-Incident Assessment (PIA) report outlines the vulnerabilities and gaps in an organization's posture, analyzing the series of events that led to the attack, and recommendations to mitigate future attacks, in-line with the compliance frameworks SOC 2, and ISO/IEC 27001:2022.

2.0 COMPANY PROFILE

National Energy is one of Canada's largest energy corporations, that employ more than 10,000 personnel across the country. The organization operates corporate offices in Toronto, Edmonton, and Vancouver, in addition to managing a nationwide network of several hundred retail gas stations. The company plays a significant role in Canada's energy sector and relies heavily on interconnected information systems to support its corporate operations, retail locations, and internet communications. According to the most recent financial disclosures, National Energy reported annual profits exceeding CAD \$20 billion, representing an increase from the previous year's profit of CAD \$18.5 billion.

Prior to the incident described in this report, National Energy had not experienced a significant cybersecurity breach resulting in prolonged operational disruption. Information security responsibilities are managed by a dedicated cybersecurity team of approximately 40 personnel, with the majority based in the Toronto office. The corporate offices are connected through a shared enterprise network that supports remote communication, centralized business operations, and the exchange of sensitive corporate information between locations.

3.0 ATTACK TIMELINE

Based on the information provided, the attack began when threat actors exploited a vulnerability in a third-party authentication provider used by National Energy. Through this compromise, the attackers obtained valid employee credentials and used them to gain unauthorized access to the organization's internal systems. After establishing internal access, the attackers successfully escalated privileges, ultimately obtaining administrative-level access to critical systems. The elevated privileges allowed the attackers to move laterally throughout the system and access systems containing sensitive corporate data.

Before deploying the ransomware, the attackers exfiltrated company data from multiple systems. Following the data being exfiltrated, ransomware was executed across the system, resulting in the encryption of sensitive data and the disruption of normal business operations. The attackers demanded payment in exchange for a decryption key and prevent the public release of the stolen data.

The ransomware infection spread throughout the organization's shared enterprise network, affecting all the corporate locations and disrupting the connectivity between offices. As a result, employees lost access to critical business systems, and several operational functions became unavailable. Retail gas stations experienced service disruptions that prevented normal electronic payment processing, which required temporary contingency procedures to maintain operations.

The incident was not identified until operational disruptions became apparent to employees and business units. Following detection of the attack, National Energy initiated its incident response and recovery procedures including the isolation of affected systems, forensic investigation activities, credential resets, restoration planning, and the rebuilding of compromised endpoints from trusted sources.

4.0 ATTACK ANALYSIS

This incident demonstrates multiple failures across preventive, detective, and corrective security controls. While the initial compromise originated through a third-party authentication provider, the resulting business impact was primarily caused by deficiencies in National Energy's internal identity management, privilege governance, network architecture, endpoint detection capabilities, and security monitoring. The assessment identifies deficiencies that would likely constitute significant findings during an ISO/IEC 27001:2022 information security management system audit and a SOC 2 Type II examination of the Security and Availability Trust Services Criteria.

4.1 FINDING A – THIRD-PARTY RISK MANAGEMENT

Control Objective

Third-party service providers should be governed through formal risk management processes that ensure security controls remain effective throughout the supplier relationship.

Observation

Attackers exploited a vulnerability within the third-party authentication provider and successfully obtained valid National Energy employee credentials.

No evidence indicates:

- Continuous supplier security monitoring
- Contractual security requirements
- Security assessment of the authentication provider
- Compromise notification procedures
- Identity federation monitoring

The compromise of a single external supplier directly resulted in unauthorized access to National Energy's internal environment.

Risk	Dependence upon a third-party identity provider without sufficient vendor governance significantly increases organizational exposure to supply chain attacks. A compromise of supplier infrastructure may bypass perimeter security controls while presenting attackers with legitimate credentials that appear authentic.
Impact	• Unauthorized access established • Initial foothold obtained • Compromise occurred without detection
Severity	High
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.19 • SOC 2 CC9.2
References	[1] , [2]

4.2 FINDING B – IDENTITY AND PRIVILEGED ACCESS MANAGEMENT FAILURES

Control Objective

Privileged access should be granted only under controlled conditions, continuously monitored, and restricted according to least privilege.

Observation

Following credential compromise, attackers successfully escalated privileges until administrative access was obtained. The scenario provides no indication that privileged access events generated alerts, required approval, or triggered security monitoring. Administrative privilege escalation therefore occurred without containment.

Risk	Administrative privileges provide unrestricted access to enterprise infrastructure. Failure to monitor privilege elevation substantially increases the likelihood of: • Ransomware deployment • Credential thief • Domain compromise • Destructive system modification
Impact	Attackers obtained unrestricted administrative access across the enterprise environment. This represented the critical turning point that enabled lateral movement and ransomware deployment.
Severity	Critical
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.2 • SOC 2 CC6.3
References	[3] , [4]

4.3 FINDING C – AUTHENTICATION CONTROL DEFICIENCY

Control Objective

Authentication mechanisms should provide reasonable assurance that only authorized users gain system access.

Observation

The attackers authenticated using valid employee credentials obtained from the compromised supplier.

The scenario provides no evidence that:

- MFA was enforced
- Conditional access policies existed
- Impossible travel detection existed
- Device trust policies were configured
- Anomalous authentication monitoring occurred

The compromise of a single password therefore resulted in successful organizational access.

Risk	Password only authentication represents a significant control weakness against modern credential theft attacks. Modern ransomware operators routinely obtain credentials through phishing, infostealer, malware, or supplier compromise. Without additional authentication factors, possession of credentials alone is sufficient to bypass access controls.
Impact	Initial access succeeded without generating security alerts.
Severity	High
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.15 • ISO/IEC 27001:2022 Annex 8.5 • SOC 2 CC6.1 • SOC 2 CC6.2
References	[5] , [6] , [7] , [8]

4.4 FINDING D – NETWORK SEGMENTATION AND LATERAL MOVEMENT CONTROLS

Control Objective

Enterprise networks should be segmented to restrict lateral movement and contain security incidents.

Observation

Following administrative compromise, ransomware propagated across multiple corporate offices and disrupted connectivity nationwide.

The attack affected:

- Toronto
- Edmonton
- Vancouver
- Retail gas stations

The observed attack path indicates inadequate network segmentation and insufficient internal access restrictions.

No evidence suggests:

- VLAN segmentation
- Zero Trust architecture
- Internet firewalls
- East-west traffic monitoring
- Privileged network isolation

Risk	Flat enterprise networks significantly increase ransomware propagation. Compromise of a single administrative account can rapidly affect the entire enterprise environment.
Impact	Corporate operations and retail services experienced organization wide disruption. Availability of critical business systems was lost.
Severity	Critical
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.20 • ISO/IEC 27001:2022 Annex A 8.22 • SOC 2 CC6.1
References	[9] , [10] , [7]

4.5 FINDING E – SECURITY MONITORING AND INCIDENT DETECTION

Control Objective

Security events should be continuously monitored to detect malicious activity before significant business impact occurs.

Observation

The incident was not detected until ransomware caused operational disruption.

No evidence indicates adequate:

- SIEM monitoring
- Endpoint detection and response (EDR)
- Privileged activity monitoring
- Behavioral analytics
- Centralized log correlation
- Automated alerting

Attackers successfully completed every stage of the intrusion lifecycle before organizational detection.

Risk	Delayed detection substantially increases: • Dwell time • Ransomware success • Data exfiltration • Recovery costs Organizations that detect attacks only after operational disruption generally experience significantly greater business impact.
Impact	Detection occurred after: • Credential compromise • Privilege escalation • Lateral movement • Data exfiltration • Ransomware movement
Severity	Critical
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.24 • SOC 2 CC7.2 • SOC 2 CC7.3 • SOC 2 CC7.4
References	[11] , [12] , [13] , [14]

4.6 FINDING F – ENDPOINT SECURITY CONTROLS

Control Objective

Endpoints should implement technical controls capable of preventing malware execution and detecting malicious behaviour.

Observation

Ransomware executed successfully across enterprise endpoints. There is no evidence that National Energy adequately deployed:

- Endpoint Detection and Response (EDR)
- Application allowlisting
- Anti-malware behavioural detection

- Ransomware rollback rules
- Attack surface reduction rules

The successful execution and propagation of ransomware indicate ineffective endpoint protection.

Risk	Endpoint devices represent the primary execution point for ransomware. Without behavioural detection and execution prevention, malware can encrypt enterprise data before containment measures are initiated.
Impact	Enterprise-wide encryption disrupted business operations and prevented employee access to critical systems.
Severity	Critical
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.7 • SOC 2 CC6.8
References	[15] , [8]

4.7 OVERALL OPINION

Based on the evidence provided, the assessed control environment exhibits significant deficiencies across identity management, privileged access governance, network segmentation, endpoint protection, security monitoring, and third-party risk management. Collectively, these weaknesses enabled the attackers to progress through the complete ransomware attack lifecycle, including initial access, privilege escalation, lateral movement, data exfiltration, and ransomware deployment without timely detection or containment. From an audit perspective, these findings would likely result in multiple high and critical observations during an ISO/IEC 27001:2022 or SOC 2 Type II assessment. The control environment, as described, would not provide reasonable assurance that logical access, system operations, or supplier risk management controls are operating effectively to protect the confidentiality, integrity, and availability of organizational information assets.

5.0 RECOMMENDATIONS

Based on the control deficiencies identified during the assessment, National Energy should implement the following corrective actions. Recommendations have been prioritized according to the level of risk presented to the organization and are aligned with ISO/IEC 27001:2022 and SOC 2 Trust Services Criteria.

5.1 RECOMMENDATION A – IMPLEMENT ENTERPRISE ENDPOINT DETECTION AND RESPONSE (CRITICAL)

Observation

The investigation identified that malware executed successfully on endpoint systems without being prevented or detected during the early stages of the attack.

Risk	Without centrally managed endpoint protection, malicious software can execute, establish persistence, and facilitate privilege escalation, credential theft, lateral movement, and ransomware deployment.
Recommendation	Management should implement an enterprise Endpoint Detection and Response (EDR) platform across all corporate endpoints. The solution should provide: • Behavioural malware detection • Real-time monitoring • Automatic host isolation • Application control • Centralized alerting • Integration with security monitoring tools Documented procedures should also be developed for malware response, exception handling, software updates, and periodic health verification.
Priority	Critical (0-30 Days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.7 • SOC 2 CC6.8
Expected Audit Evidence	• EDR deployment reports • Endpoint compliance dashboard • Malware detection logs • Configuration baselines
References	[15] , [12] , [16]

5.2 RECOMMENDATION B – STRENGTHEN IDENTITY AND PRIVILEGED ACCESS MANAGEMENT (CRITICAL)

Observation

The assessment identified deficiencies in privileged access governance, allowing attackers to elevate privileges and move laterally throughout the environment.

Risk	Excessive or unmanaged privileges increase the likelihood of unauthorized access to critical systems and reduce accountability for administrative actions.
Recommendation	Management should implement a centralized identity and access management (IAM) solution supporting: • Role-Based Access Control (RBAC) • Multi-Factor Authentication (MFA) • Privileged Access Management (PAM) • Just-In-Time administrative access • Quarterly access reviews • Automated account deprovisioning • Administrative session logging
Priority	Critical (0-30 Days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.15 • ISO/IEC 27001:2022 Annex A 8.2 • ISO/IEC 27001:2022 Annex A 8.5 • SOC 2 CC6.1 • SOC 2 CC6.2 • SOC 2 CC6.3
Expected Audit Evidence	• Access Control Policy • RBAC matrix • MFA enforcement reports • Quarterly access review documentation • Privileged access logs
References	[3] , [4] , [18]

5.3 RECOMMENDATION C – IMPROVE NETWORK SECURITY ARCHITECTURE (HIGH)

Observation

The network architecture permitted unrestricted lateral movement between systems following initial compromise.

Risk	Insufficient network segmentation increases the likelihood that attackers can compromise multiple systems and disrupt critical business operations.
Recommendation	Management should redesign the network architecture to include: • Network segmentation • Internal firewalls • VLAN separation • Least privilege network access • DNS/Web filtering • Continuous network monitoring • Intrusion Detection/Prevention Systems (IDS/IPS)
Priority	High (30-90 days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.20 • ISO/IEC 27001:2022 Annex A 8.22 • ISO/IEC 27001:2022 Annex A 8.23 • SOC 2 CC6.1
Expected Audit Evidence	• Network diagrams • Firewall rules • IDS alerts • DNS filtering configuration • Network monitoring reports
References	[9] , [10] , [7] , [17] , [8]

5.4 RECOMMENDATION D – STRENGTHEN THIRD-PARTY RISK MANAGEMENT (HIGH)

Observation

The incident originated through a compromised third-party service, indicating insufficient supplier risk governance.

Risk	Weak supplier governance increases the likelihood that vulnerabilities within external organizations will impact National Energy's environment.
Recommendation	Management should establish a formal third-party risk management program including: • Supplier risk assessments • Security requirements within contracts • Annual supplier reviews • Evidence of compliance • Incident notification requirements • Vendor access reviews
Priority	High (30-90 days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.19 • SOC 2 CC9.2
Expected Audit Evidence	• Vendor risk assessments • Security questionnaires • Contractual security clauses • Supplier review reports
References	[1] , [2]

5.5 RECOMMENDATION E – STRENGTHEN BACKUP AND RECOVERY CONTROLS (HIGH)

Observation

The assessment identified deficiencies in the organization's backup and recovery capabilities. Based on the incident timeline, existing backup processes were insufficient to support timely restoration of critical systems following the ransomware attack.

Risk	Inadequate backup governance increases the likelihood of prolonged operational disruption, permanent data loss, and an inability to recover critical business services following a cyber incident.
Recommendation	Management should implement a comprehensive backup and disaster recovery program that ensures the confidentiality, integrity, and availability of organizational data. The backup strategy should include: • Identification of all critical systems and data requiring backup. • Encrypted backups while stored and during transmission. • Offline or immutable backup storage to protect against ransomware. • Separation of backup infrastructure from the production network. • Automated monitoring of backup job success and failures. • Periodic restoration testing to validate backup integrity. • Defined Recovery Time Objectives (RTOs) and Recovery Point Objectives (RPOs) for critical systems. • Documented backup retention and recovery procedures.
Priority	High (30-90 days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 8.13 • SOC 2 CC6.6 • SOC 2 CC6.7 • SOC 2 CC7.1 • SOC 2 A1.3
Expected Audit Evidence	• Backup and Recovery Policy • Backup schedules • Encryption configuration • Backup monitoring reports • Disaster recovery procedures • Backup restoration test results • Recovery testing logs
References	[19] , [20]

5.6 RECOMMENDATION F – FORMALIZE SECURITY MONITORING AND INCIDENT RESPONSE (HIGH)

Observation

The incident was not detected or contained during the early stages of the attack. Security monitoring, alerting, escalation procedures, and incident response activities were insufficient to prevent widespread compromise.

Risk	Delayed detection and ineffective incident response increases the likelihood that security incidents will result in extended business disruption, data loss, regulatory exposure, and financial damage.
Recommendation	Management should establish a formal Security Operations and Incident Response capability supported by documented procedures and continuous monitoring technologies. The incident response program should include: • Centralized Security Information and Event Management (SIEM) for security event correlation. • Continuous monitoring of authentication, endpoint, and network activity. • Defined security alert thresholds and escalation procedures. • Clearly assigned incident response roles and responsibilities. • Procedures for incident identification, containment, eradication, recovery, and post-incident review. • Integration of third-party incidents into response procedures. • Regular tabletop exercises and incident response testing. • Continuous improvement through lessons learned following security incidents.
Priority	High (30-90 days)
Applicable Controls	• ISO/IEC 27001:2022 Annex A 5.24 • SOC 2 CC7.3 • SOC 2 CC7.4
Expected Audit Evidence	• Incident Response Plan • SIEM configuration documentation • Security monitoring dashboards • Incident tickets • Escalation procedures • Incident response exercise reports • Post-incident review documentation
References	[11] , [13] , [14]

5.7 RECOMMENDATION G – ENHANCE SECURITY COMMUNICATION AND SECURITY AWARENESS (MEDIUM)

Observation

The assessment identified opportunities to improve internal communication processes relating to information security events and organizational security responsibilities.

Risk	Ineffective communication and limited security awareness increase the likelihood of delayed incident reporting, inconsistent response activities, and increased susceptibility to phishing, ransomware, and social engineering attacks.
Recommendation	Management should establish a formal security communication and awareness program that supports organizational security objectives and promotes timely reporting of security events. The program should include: • Documented internal and external communication procedures for security incidents. • Defined communication responsibilities during security events. • Mandatory security awareness training for all personnel. • Annual phishing awareness exercises. • Regular communication of emerging cyber threats. • Security awareness training for privileged user and executives. • Periodic review of communication effectiveness.
Priority	Medium (90-180 days)
Applicable Controls	• ISO/IEC 27001:2022 Clause 7.4 • SOC 2 CC2.2 • SOC 2 CC2.3
Expected Audit Evidence	• Information Security Communication Policy • Security Awareness Program • Employee training records • Phishing simulation results • Communication plans • Incident notification templates • Security awareness metrics
References	[21] , [22]

6.0 CONCLUSION

This assessment identified significant deficiencies within National Energy's information security control environment across multiple domains, including third-party risk management, identity and access management, network security, endpoint protection, security monitoring, incident response, and business continuity planning. Collectively, these control deficiencies enabled threat actors to progress through the ransomware attack lifecycle without timely detection or containment, resulting in unauthorized access, data exfiltration, operational disruption, and widespread business impact. The findings presented in this report indicate that the current control environment does not provide reasonable assurance that the confidentiality, integrity, and availability of critical information assets are adequately protected. As a result, National Energy remains exposed to elevated operational, financial, regulatory, and reputational risks should similar threats occur in the future.

Management should prioritize the remediation of all critical and high-risk findings and establish a formal process for monitoring the effectiveness of implemented controls. Regular internal audits, security assessments, and control reviews should be conducted to ensure continued alignment with ISO/IEC 27001:2022 and SOC 2 requirements. Provided that the recommended corrective actions are implemented and operating effectively, National Energy will be better positioned to detect, prevent, and respond to future cybersecurity threats while improving the resilience, security, and reliability of its information systems and business operations.

7.0 REFERENCES

- [1] D. Holloway, "ISO 27001:2022 Annex A control 5.19 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/5-19-information-security-supplier-relationships-2022/> (accessed Apr. 8, 2026).
- [2] S. Peters, "Soc 2 controls: Risk mitigation CC9.2 explained." isms.online.
<https://www.isms.online/soc-2/controls/risk-mitigation-cc9-2-explained/> (accessed Apr. 8, 2026).
- [3] J. Whiting, "ISO 27001:2022 Annex A Control 8.2 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/8-2-use-of-privileged-access-rights-2022/> (accessed Apr. 7, 2026).

- [4] S. Peters, "SOC 2 CC6.3: Logical & Physical Access." isms.online.
<https://www.isms.online/soc-2/controls/logical-and-physical-access-controls-cc6-3-explained/> (accessed Apr. 7, 2026).
- [5] D. Holloway, "ISO 27001:2022 Annex A control 5.15 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/5-15-access-control-2022/> (accessed Apr. 14, 2026).
- [6] J. Whiting, "ISO 27001:2022 Annex A Control 8.5 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/8-5-secure-authentication-2022/> (accessed Apr. 15, 2026).
- [7] S. Peters, "SOC 2 CC6.1: Logical & Physical Access." isms.online.
<https://www.isms.online/soc-2/controls/logical-and-physical-access-controls-cc6-1-explained/> (accessed Apr. 11, 2026).
- [8] "Soc 2 controls CC6: Logical & Physical Access." hicomply.com.
<https://www.hicomply.com/hub/soc-2-controls-cc6-logical-and-physical-access-controls> (accessed Apr. 13, 2026).
- [9] J. Whiting, "ISO 27001:2022 Annex A control 8.20 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/8-20-network-security-2022/> (accessed Apr. 10, 2026).
- [10] J. Whiting, "ISO 27001:2022 Annex A control 8.22 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/8-22-segregation-of-networks-2022/> (accessed Apr. 10, 2026).
- [11] T. Cane, "ISO 27001:2022 Annex A control 5.24 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/5-24-incident-management-planning-and-preparation-2022/> (accessed Apr. 23, 2026).
- [12] "A guide to SOC 2 compliance & audit requirements." blumira.com.
<https://www.blumira.com/compliance/soc2-compliance> (accessed Apr. 5, 2026).
- [13] S. Peters, "SOC 2: System operations CC7.3 explained." isms.online.
<https://www.isms.online/soc-2/controls/system-operations-cc7-3-explained/> (accessed Apr. 28, 2026).
- [14] S. Peters, "SOC 2 - System Operations CC7.4 explained." isms.online.
<https://www.isms.online/soc-2/controls/system-operations-cc7-4-explained/> (accessed May 1, 2026).

- [15] T. Cane, "ISO 27002, Control 8.7, protection against malware." isms.online.
<https://www.isms.online/iso-27002/control-8-7-protection-against-malware/> (accessed Apr. 5, 2026).
- [16] Canadian Centre for Cyber Security, "Ransomware: How to prevent and recover (ITSAP.00.099)." cyber.gc.ca. <https://www.cyber.gc.ca/en/guidance/ransomware-how-prevent-and-recover-itsap00099> (accessed Apr. 6, 2026).
- [17] J. Whiting, "ISO 27001:2022 Annex A control 8.23 explained." isms.online.
<https://www.isms.online/iso-27001/annex-a-2022/8-23-web-filtering-2022/> (accessed Apr. 13, 2026).
- [18] J. Soong, "Meeting MFA control requirements for compliance – authsignal." authsignal.com. <https://www.authsignal.com/blog/articles/how-to-meet-compliance-requirements-for-multi-factor-authentication-mfa-controls> (accessed Apr. 16, 2026).
- [19] M. Jennings, "ISO 27001:2022 Annex A control 8.13 explained," isms.online,
<https://www.isms.online/iso-27001/annex-a-2022/8-13-information-backup-2022/> (accessed Apr. 16, 2026).
- [20] Ł. Dydek, "Ensuring backup compliance with SOC 2 and ISO 27001." infosecurity-magazine.com. <https://www.infosecurity-magazine.com/blogs/ensuring-backup-compliance-soc2/> (accessed Apr. 17, 2026).
- [21] "ISO 27001:2022 requirement 7.4 – communication." dataguard.com.
<https://www.dataguard.com/iso-27001/clause-7-4-communication/> (accessed Apr. 17, 2026).
- [22] "Soc 2 controls CC2: Communication & Information." hicomply.com.
<https://www.hicomply.com/hub/soc-2-controls-cc2-communication-and-information> (accessed Apr. 20, 2026).